

Cirque Corporation

Privileged Access Management Procedure

Document ID: IS-CIRQ-PR-009-G

Category: IT Security Related

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the requirements and processes for the secure management of privileged access within Cirque's IT environment. This procedure aims to minimize the risks associated with the misuse or compromise of privileged accounts, in accordance with IS-CIRQ-P-008-G: Access Control Policy and ISO/IEC 27001:2022 Annex A.8.2.

****2. Scope****

2. Scope

This procedure applies to all privileged accounts and credentials across Cirque's information systems, networks, applications, and infrastructure, regardless of location (on-premises, cloud services).

This includes, but is not limited to:

- Domain Administrator accounts (Active Directory)
- Local Administrator accounts on servers and workstations

- Database Administrator accounts
- Application Administrator accounts (e.g., Omnify, Cadence, GitLab, Asana, Microsoft 365, QuickBooks)
- Network device administrator accounts (e.g., firewalls, switches)
- Cloud service provider administrative accounts (e.g., Azure, AWS)
- Physical access control system administrators (e.g., Unifi Access)
- Service accounts with elevated privileges

****3. Definitions****

3. Definitions

- ****Privileged Account:**** Any user account, service account, or shared account that has elevated permissions beyond those of a standard user, allowing it to perform critical system functions, access sensitive data, or configure/modify system settings.
- ****Just-in-Time (JIT) Access:**** A method of granting elevated privileges for a limited time and specific task, typically expiring automatically.
- ****Need-to-Use:**** The principle that privileged access is only granted when it is absolutely necessary for a specific, authorized task.

****4. Responsibilities****

4. Responsibilities

- ****IT Manager:**** Overall owner of this procedure. Responsible for managing privileged accounts, enforcing privileged access policies, conducting regular reviews, and monitoring privileged activity.

- **System Administrators / IT Personnel:** Responsible for using privileged accounts strictly in accordance with this procedure.
- **Executive Committee:** Approves high-level strategy for privileged access and provides necessary resources.

5. Procedure

5. Procedure

5.1. Identification of Privileged Accounts a. The IT Manager shall maintain a comprehensive inventory of all identified privileged accounts, including their purpose, associated systems, and the individuals authorized to use them. b. This inventory shall be reviewed at least quarterly.

5.2. Creation and Management of Privileged Accounts a. **Dedicated Accounts:** Wherever possible, separate, individual accounts shall be created for each administrator requiring privileged access. These accounts shall be distinct from their standard user accounts. * Example: An administrator named \"John Doe\" would have a standard user account (johndoe) for daily tasks and a separate privileged account (jd-admin) for administrative functions. b. **Unique Credentials:** Each privileged account shall have a unique, strong password. c. **Minimal Privileges:** Privileged accounts shall be configured with the absolute minimum set of permissions necessary to perform their intended function (least privilege principle). d. **Generic/Shared Accounts:** Use of generic or shared privileged accounts (e.g., \"administrator\") is strictly prohibited unless technically unavoidable. In such cases, usage must be strictly controlled, logged, monitored, and reviewed, with individual accountability ensured through other means (e.g., session recording, strict check-out/check-in process).

****5.3. Authentication for Privileged Access**** a. ****Strong Passwords:**** All privileged accounts shall enforce Cirque's strong password policy (complexity, length, non-repetition). b. ****Multi-Factor Authentication (MFA):**** MFA shall be mandatory for all privileged accounts, including ****Active Directory domain administrator accounts****, access to critical cloud platforms (e.g., Azure, Microsoft 365 Admin Centers), and network device administration. c. ****Secure Workstations:**** Privileged administrative tasks shall ideally be performed from designated, hardened administrative workstations that are logically separated from standard user networks and services.

****5.4. Granting and Revoking Privileged Access**** a. ****Formal Request & Approval:**** All requests for new or modified privileged access must be formally documented (e.g., via a ticketing system or email approval) and approved by the IT Manager and/or relevant Department Manager. The request must include a clear business justification and the duration for which access is required. b. ****Time-Limited Access (Just-in-Time):**** Where possible, privileged access shall be granted on a time-limited (Just-in-Time) basis, automatically expiring after a specified duration (e.g., 4 or 8 hours) or upon completion of the task. c. ****Prompt Revocation:**** Privileged access shall be immediately revoked when no longer required due to role changes, termination of employment/contract, or completion of a specific task.

****5.5. Monitoring and Logging of Privileged Activity**** a. ****Comprehensive Logging:**** All activities performed using privileged accounts shall be extensively logged on all relevant systems (****Active Directory, server event logs, application logs, network device logs, cloud platform audit logs****). Logs shall include user, date/time, action performed, and system/resource accessed. b. ****Centralized Logging:**** Logs from privileged activity should be sent to a centralized log

management system for correlation and analysis. c. ****Alerting:**** Alerts shall be configured for suspicious or unauthorized activities involving privileged accounts (e.g., multiple failed login attempts, access to unusual resources, changes to critical configurations). d. ****Regular Review:**** The IT Manager shall regularly review privileged access logs (e.g., daily for critical systems, weekly for others) for anomalies or policy violations.

****5.6. Periodic Review of Privileged Access**** a. The IT Manager shall conduct a formal review of all privileged accounts and their associated access rights at least ****quarterly****. b. This review includes: * Verifying continued need for each privileged account. * Confirming that assigned permissions align with least privilege. * Identifying and disabling dormant or unnecessary privileged accounts. * Reviewing audit trails of privileged activity. c. Documentation of the review findings and any actions taken shall be maintained.

****5.7. Secure Configuration and Maintenance**** a. Privileged accounts, systems, and tools shall be securely configured (e.g., following hardening guides like CIS benchmarks) and regularly patched. b. Shared secrets (e.g., service account passwords) shall be managed securely within a password vault solution if applicable.

****6. Training and Awareness****

6. Training and Awareness

All personnel granted privileged access shall receive specific training on the requirements of this procedure, the responsible use of privileged accounts, and the potential impact of misuse.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-P-008-G: Access Control Policy
- IS-CIRQ-PR-008-G: Access Control Procedure
- IS-CIRQ-PR-006-G: Document Control Procedure (for managing this procedure)
- IS-CIRQ-P-001-G: Information Security Policy

****8. Procedure Review****

8. Procedure Review

This procedure will be reviewed at least annually, or sooner if significant changes occur to Cirque's IT infrastructure, threat landscape, or relevant regulations.